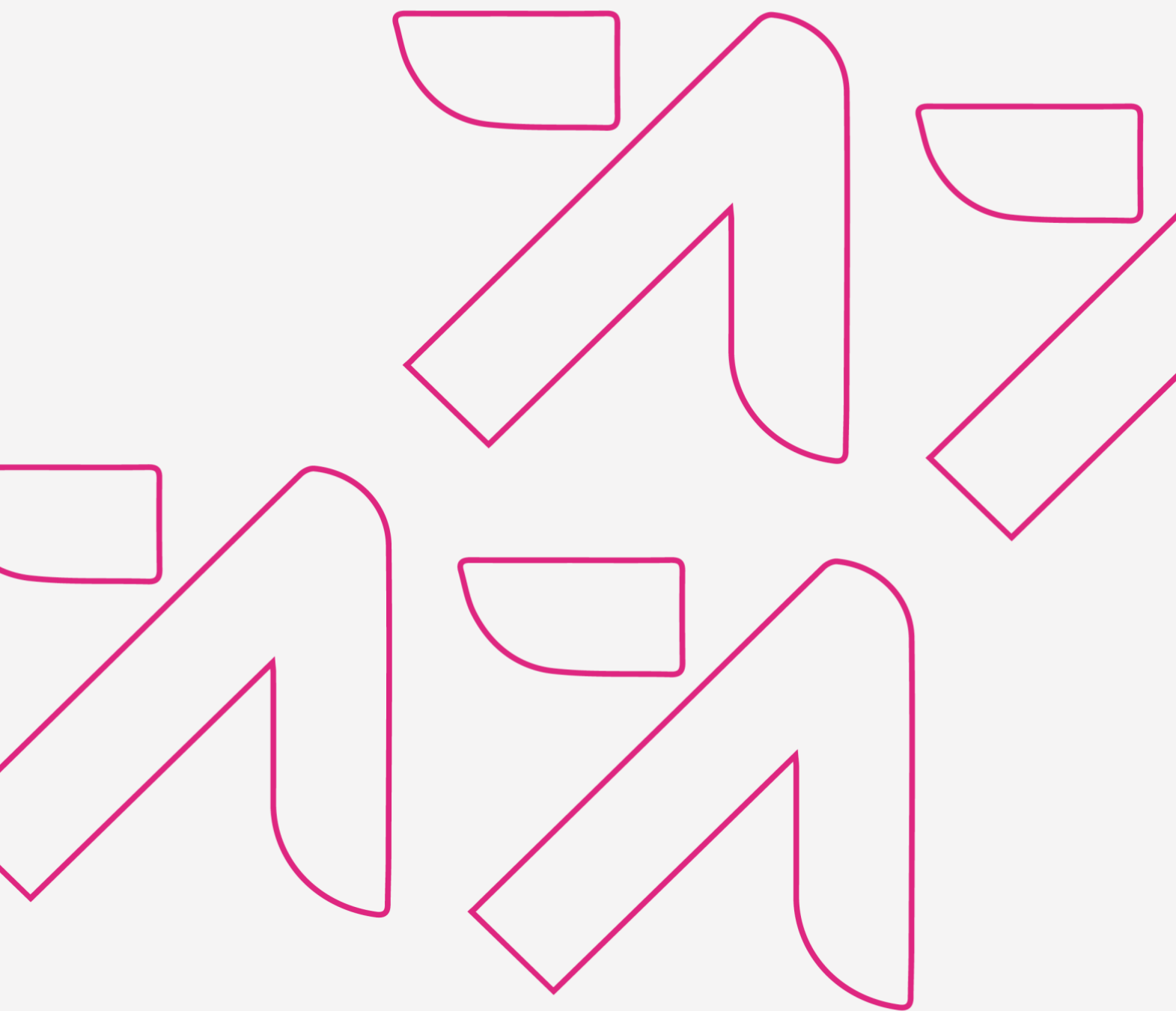




Máster de

Ciberseguridad Hacking Ético

[Módulo Incidentes de Ciberseguridad]

Curso académico 2026/2027 - Edición Presencial

Tema 3. Taxonomía y clasificación de incidentes de ciberseguridad

Encaje en el curso 2026/2027: tema 3 del temario oficial, dentro del RA1. Clasificar bien es lo que permite priorizar y, más adelante, notificar correctamente.

1. Amenazas

1.1. Malware

Tipo	Qué hace
Virus	Se adjunta a ficheros y necesita que alguien los ejecute
Gusano	Se propaga solo por la red aprovechando vulnerabilidades
Troyano	Se hace pasar por software legítimo
Ransomware	Cifra o bloquea y pide un rescate
Spyware / infostealer	Roba credenciales, cookies de sesión y datos
Keylogger	Registra las pulsaciones del teclado
Rootkit	Se oculta en el sistema para mantener el acceso
Botnet	Convierte el equipo en parte de una red controlada por el atacante
Malware sin fichero	Vive en memoria y usa herramientas del propio sistema (PowerShell, WMI)

Los infostealers merecen atención especial: las credenciales y sesiones que roban se venden y son hoy el punto de partida de muchos ataques de ransomware.

1.2. Ingeniería social

Phishing, spear phishing, smishing, vishing, pretexting y fraude del CEO, vistos en el tema 2.

1.3. Fraudes

- Fraude de facturas y cambio de cuenta bancaria.
- Falsas tiendas en línea y falsos soportes técnicos.
- Suplantación de marca en dominios y redes sociales.

1.4. Amenazas físicas y de comportamiento

- Acceso físico no autorizado, robo o pérdida de equipos y soportes.
- Personal interno: malintencionado, descuidado o manipulado.
- Uso de servicios y dispositivos no autorizados (TI en la sombra).

2. Del riesgo al incidente

Un incidente es un riesgo que se ha materializado. La evaluación de riesgos (probabilidad por impacto), que se trabaja a fondo en Bastionado, sirve aquí para dos cosas: decidir qué casos de uso de detección se montan primero y valorar la gravedad de un incidente cuando ocurre.

3. Fases de un ataque: Cyber Kill Chain

El modelo de Lockheed Martin describe un ataque como una cadena de siete eslabones. Su utilidad práctica: si se rompe uno, el ataque se detiene, y cuanto antes se rompa, menos daño.

Fase	Qué hace el atacante	Cómo se frena o detecta
1. Reconocimiento	Recopila información del objetivo	Reducir la información pública; vigilar escaneos
2. Preparación	Prepara el malware o el señuelo	Ciberinteligencia: conocer sus herramientas
3. Distribución	Lo hace llegar: correo, web, USB	Filtrado de correo y navegación; concienciación
4. Explotación	Aprovecha una vulnerabilidad o un clic	Parches; bastionado; EDR
5. Instalación	Deja persistencia en el equipo	EDR; control de aplicaciones; integridad de ficheros
6. Mando y control	El equipo contacta con el atacante	Filtrado de salida; DNS; IDS
7. Acciones sobre el objetivo	Roba, cifra o destruye	Segmentación; copias; detección de exfiltración

4. MITRE ATT&CK

La Kill Chain es una visión general. MITRE ATT&CK baja al detalle: es una base de conocimiento pública de **tácticas** (el objetivo del atacante en cada momento, como acceso inicial o movimiento lateral) y **técnicas** (cómo lo consigue, cada una con un identificador, por ejemplo T1566 para phishing).

Se usa como idioma común: para describir un incidente, para saber qué técnicas detectan nuestras herramientas y para comparar un ataque con los de grupos conocidos. Wazuh y la mayoría de herramientas etiquetan sus alertas con la técnica de ATT&CK correspondiente.

5. Ransomware

5.1. Tipos

- **Scareware:** falsas alertas que asustan para que se pague o se instale algo.
- **Bloqueadores de pantalla:** impiden usar el equipo sin cifrar los datos.
- **Ransomware de cifrado:** cifra los ficheros y pide rescate por la clave.
- **Ransomware como servicio (RaaS):** un grupo desarrolla el malware y lo alquila a afiliados que ejecutan los ataques a cambio de una comisión.

5.2. Cómo actúan hoy

- **Doble extorsión:** antes de cifrar, roban los datos y amenazan con publicarlos. Las copias de seguridad resuelven el cifrado, pero no la fuga.
- **Triple extorsión:** añaden presión sobre clientes, o ataques DDoS.
- Pasan días o semanas dentro antes de cifrar: buscan y destruyen primero las copias de seguridad.

5.3. ¿Pagar?

La recomendación de INCIBE, CCN-CERT y las fuerzas de seguridad es no pagar: no garantiza recuperar los datos, financia al grupo y señala a la víctima como buena pagadora.

6. La taxonomía oficial

En España, la clasificación de referencia es la de la **Guía Nacional de Notificación y Gestión de Ciberincidentes**, alineada con la taxonomía europea. Es la que hay que usar al notificar.

Clase	Ejemplos de tipos
Contenido abusivo	Spam, delitos de odio, contenido ilegal
Contenido dañino	Malware, sistema infectado, servidor de mando y control
Obtención de información	Escaneo de redes, análisis de tráfico, ingeniería social
Intento de intrusión	Explotación de vulnerabilidades, intento de acceso con credenciales
Intrusión	Compromiso de cuenta, de aplicación o de sistema; robo
Disponibilidad	DoS, DDoS, sabotaje, interrupciones
Compromiso de la información	Acceso, modificación o pérdida no autorizada de datos
Fraude	Uso no autorizado de recursos, suplantación, phishing
Vulnerable	Sistemas con criptografía débil, servicios expuestos, sistema vulnerable

Otros	Lo que no encaja en las anteriores; amenazas persistentes avanzadas
-------	---

Un mismo caso puede tocar varias clases a lo largo de su evolución: empieza como fraude (phishing), sigue como intrusión (cuenta comprometida) y acaba como compromiso de la información.

7. Peligrosidad e impacto

La guía pide valorar cada incidente con dos criterios distintos:

- **Peligrosidad:** lo dañina que es la amenaza en sí, con independencia de a quién afecte. Niveles: bajo, medio, alto, muy alto y crítico. Un escaneo es de peligrosidad baja; un ransomware, muy alta.
- **Impacto:** las consecuencias reales para esta organización. Niveles: sin impacto, bajo, medio, alto, muy alto y crítico. Se valora por sistemas y usuarios afectados, tiempo de interrupción, datos comprometidos, daño económico y reputacional.

En la práctica se toma como referencia el más alto de los dos, y de él dependen los plazos de notificación y la urgencia de la respuesta.

8. Priorizar

Con varios incidentes abiertos y un equipo pequeño, hay que ordenar. Preguntas que deciden:

- ¿Está activo ahora mismo o ya ha terminado?
- ¿Puede extenderse a otros sistemas?
- ¿Afecta a un servicio crítico o a datos personales?
- ¿Hay plazo legal corriendo?

Un incidente activo y con capacidad de propagación va siempre antes que uno grave pero contenido.

Para ampliar

- Guía Nacional de Notificación y Gestión de Ciberincidentes: taxonomía, peligrosidad e impacto.
- MITRE ATT&CK (attack.mitre.org).
- Lockheed Martin: Cyber Kill Chain.
- Proyecto No More Ransom: herramientas de descifrado gratuitas.